

Information_Security_Classified_Protection

Technical Standard

保险公司 技术开发部
内部文档 · 仅供授权人员查阅

Contents

1. Overview
2. Classification Standards
 - 2.1 Protection Levels
 - 2.2 Recommended Classification for Insurance Systems
3. MLPS Level 3 Technical Requirements
 - 3.1 Physical Security
 - 3.2 Network Security
 - 3.3 Host Security
 - 3.4 Application Security
 - 3.5 Data Security
4. Assessment Preparation
 - 4.1 Assessment Process
 - 4.2 Tech Team Responsibilities

Information Security Classified Protection Standard

1. Overview

This document defines technical requirements for implementing the Information Security Classified Protection System (MLPS 2.0 / ■■ 2.0), covering general and extended security requirements. It applies to all core systems and application systems handling customer information.

2. Classification Standards

2.1 Protection Levels

Level	Definition	Example Systems
Level 1	Self-protection	Public portal website
Level 2	Guided protection	Internal office systems
Level 3	Supervised protection	Core business systems (UW, Claims, Payment, Policy)
Level 4	Mandatory protection	Systems with large volumes of sensitive personal information

2.2 Recommended Classification for Insurance Systems

System	Level	Rationale
Underwriting Center	Level 3	Premium and customer info
Payment Center	Level 3	Financial transactions
Claims Center	Level 3	Customer info and payments
Policy Center	Level 3	Core policy data
Customer Center	Level 3	Large volumes of personal data
Product Center	Level 2	No direct customer data
Office OA	Level 2	Internal management

3. MLPS Level 3 Technical Requirements

3.1 Physical Security

- Access control: Biometric + card + logging
- Environmental: Precision AC, temperature/humidity monitoring
- Power: UPS + generator, ≥ 4h runtime
- Fire protection: Gas-based suppression
- Surveillance: 7×24 recording, ≥ 90 days retention

3.2 Network Security

- Network isolation: VPC + security groups + subnets
- Access control: Firewall whitelist, least privilege
- Intrusion detection: IDS/IPS
- Bandwidth management: QoS for core services

- Security audit: Network traffic logs, ≥ 6 months retention

3.3 Host Security

- OS hardening: Baseline scanning, minimal services
- Vulnerability management: Monthly scans, quarterly penetration testing
- Anti-malware: HIDS + antivirus
- Login control: SSH Key + bastion host
- Audit logs: Centralized host operation logs

3.4 Application Security

- Two-factor authentication
- Fine-grained access control
- Full audit logging
- Data integrity verification
- End-to-end encryption

3.5 Data Security

- Data classification by sensitivity
- AES-256 storage encryption
- Daily full + incremental backup, offsite copies
- Privacy protection: masking + encryption + access control
- Data destruction: degaussing/physical shredding

4. Assessment Preparation

4.1 Assessment Process

Classification & Filing → Gap Assessment → Remediation → Certification Assessment → Continuous Monitoring

4.2 Tech Team Responsibilities

- Provide system inventory, network topology, data flow diagrams
- Coordinate vulnerability scanning and remediation
- Provide security management documentation
- Support on-site assessment and interviews
- Provide change records after remediation